Politechnika Krakowska
im. Tadeusza Kościuszki
Wydział Informatyki i Matematyki

Wykrywanie Zagrożeń i Reakcja na Incydenty

Porównanie reakcji na incydenty w środowisku on-premise vs. cloud

28.05.2026

Michał Wilk, 147017
Wiktor Zmiendak, 142706

SPIS TREŚCI

1.Wprowadzenie 4
2.Segment teoretyczny 4
2.1Ewolucja standardu NIST SP 800-61 4
2.2Porównanie struktur NIST SP 800-61 Revision 2 i 3 5
3.Porównanie on-premise i cloud w kluczowych domenach 6
3.1Kontrola i model odpowiedzialności współdzielonej 6
3.1.1Absolutna kontrola w środowisku on-premise 6
3.1.2Model odpowiedzialności współdzielonej w chmurze 6
3.2Widoczność i telemetria 7
3.2.1Możliwości i ograniczenia w środowisku on-premise 7
3.2.2Taksonomia logów chmurowych 7
3.2.3Narzędzia natywne dostawcy a zewnętrzny SIEM 8
3.3Cykl życia IR 8
3.3.1Wykrywanie i analiza 8
3.3.2Powstrzymywanie 8
3.3.3Usuwanie i odzyskiwanie 9
3.4Informatyka śledcza 9
3.5Porównanie technicznych aspektów informatyki śledczej 10
3.6Automatyzacja i SOAR 11
3.7Prawo i aspekty regulacyjne 11
4.Analiza luk w procesach tradycyjnych 12
4.1Tożsamość jako nowy obwód bezpieczeństwa 12
4.2Eksplozja skali i prędkości 12
4.2.1Ataki na prędkości API 12
4.2.2Potrzeba reagowania na prędkość maszyny 13
4.3Efemeryczność artefaktów i "Fog of War" 13
4.3.1Kontenery bez tradycyjnego systemu plików 13
4.3.2Fog of War 13
5.Modelowanie procesów docelowych - Reagowanie napędzane przez kod 14
5.1Architektura zdarzeniowa 14
5.2Przykładowe automatyzacje SOAR w chmurze 14
5.3Infrastruktura jako kod (IaC) jako mechanizm odzyskiwania 15

6.Uwarunkowania prawne i regulacyjne w Polsce na rok 2026 15
6.1Nowelizacja UKSC i dyrektywa NIS2 15
6.2Sektor finansowy i rozporządzenie DORA 16
6.3Dopuszczalność dowodów cyfrowych z chmury 16
7.Wnioski i rekomendacje strategiczne 16
7.1Kluczowe wnioski z niniejszego raportu 17
7.2Rekomendacje dla organizacji 17

Streszczenie

Niniejszy raport stanowi kompleksową analizę porównawczą procesów reagowania na incydenty w tradycyjnych środowiskach on-premise oraz dynamicznych architekturach chmurowych. Gwałtowne zmiany technologiczne sprawiają, że klasyczne podejście do bezpieczeństwa, zakorzenione w statycznej infrastrukturze, staje się anachronizmem. Opracowanie identyfikuje kluczowe różnice operacyjne oraz luki w podejściu tradycyjnym, wskazując niezbędne kierunki ewolucji systemów ochronnych w oparciu o najnowsze wytyczne międzynarodowe oraz polskie uwarunkowania prawne.

W pracy omówiono wycofanie standardu NIST SP 800-61 Revision 2 na rzecz Revision 3. Nowy model odchodzi od linearnego cyklu życia incydentu, integrując działania IR bezpośrednio z ramami NIST Cybersecurity Framework 2.0 i kładąc nacisk na ciągłe zarządzanie ryzykiem oraz budowanie odporności organizacji.

Zestawiono absolutną kontrolę nad fizycznym stosem technologicznym w on-premise z umowną kontrolą w chmurze, wynikającą z modelu odpowiedzialności współdzielonej. Wykazano, że tradycyjna telemetria oparta na Syslogu i portach SPAN ustępuje miejsca wielowarstwowym logom wywołań API płaszczyzny zarządzania.

Wskazano, że tradycyjne procedury manualne są bezużyteczne wobec zagrożeń rozwijających się z prędkością maszynową oraz w obliczu efemeryczności środowisk serverless i kontenerowych, które generują zjawiska takie jak „Fog of War”. Rozwiązaniem staje się głęboka automatyzacja procesów za pomocą platform klasy SOAR i predefiniowanych playbooków.

Przeanalizowano techniczne aspekty zabezpieczania dowodów cyfrowych, gdzie fizyczne obrazy bitowe dysków są zastępowane logicznymi snapshotami wolumenów wirtualnych. W fazie odzyskiwania zaprezentowano podejście oparte na infrastrukturze niemutowalnej, w którym zamiast naprawy skażonych systemów stosuje się ich natychmiastowe odtworzenie z czystych szablonów kodu.

Przeanalizowano wpływ nowelizacji ustawy o Krajowym Systemie Cyberbezpieczeństwa, która nakłada rygorystyczne terminy zgłaszania poważnych incydentów (24h/72h) przez rządowy system S46. Uwzględniono także specyficzne obowiązki sektora finansowego w ramach rozporządzenia DORA oraz prawne aspekty zapewnienia integralności dowodów z chmury poprzez niezmienialne kontenery.

Raport zakończony jest rekomendacjami strategicznymi, wśród których kluczowe znaczenie ma wdrożenie ekosystemu CNAPP i CDR, ostateczne odejście od podejścia linearnego na rzecz ciągłego zarządzania ryzykiem oraz przekwalifikowanie zespołów SOC w stronę zaawansowanej analizy logów chmurowych i interfejsów API.

1. Wprowadzenie

Zmiany technologiczne, jakich doświadczają współczesne organizacje, wymuszają fundamentalną zmianę paradygmatów bezpieczeństwa informatycznego. Tradycyjne podejście do reagowania na incydenty, zakorzenione w statycznej i w pełni kontrolowanej infrastrukturze on-premise, staje się anachronizmem w obliczu dynamicznych i wysoce rozproszonych środowisk chmurowych. Niniejszy raport stanowi kompleksową analizę porównawczą procesów IR (Incident response), mającą na celu zidentyfikowanie kluczowych różnic operacyjnych, luk w podejściu tradycyjnym oraz wytyczenie kierunków ewolucji cyklu życia incydentu zgodnie z najnowszymi wytycznymi NIST oraz specyficznymi uwarunkowaniami prawnymi obowiązującymi w Polsce na czas tworzenia tego raportu.

2. Segment teoretyczny

2.1 Ewolucja standardu NIST SP 800-61

Kluczowym punktem odniesienia dla każdej nowoczesnej strategii reagowania na incydenty jest ewolucja standardów publikowanych przez National Institute of Standards and Technology (NIST). Przez ponad dekadę publikacja “SP 800-61 Revision 2” stanowiła fundament działań operacyjnych zespołów SOC (Security Operations Center) i CSIRT (Computer Security Incident Response Team), definiując liniowy cykl życia incydentu składający się z faz przygotowania, wykrywania i analizy, powstrzymywania, usuwania i odzyskiwania oraz działań po incydencie. Jednakże, z dniem 3 kwietnia 2025 roku, NIST oficjalnie wycofał tę rewizję, wprowadzając w jej miejsce „SP 800-61 Revision 3”, co stanowiło bezpośrednią odpowiedź na rosnącą złożoność środowisk chmurowych i hybrydowych.

„Revision 3” wprowadza zmianę paradygmatu, integrując proces reagowania na incydenty bezpośrednio z ramami NIST Cybersecurity Framework 2.0. Zamiast izolowanego, reaktywnego procesu, IR staje się teraz ciągłym zarządzaniem ryzykiem, rozproszonym pomiędzy sześć głównych funkcji CSF w skład których wchodzi Govern, Identify, Protect, Detect, Respond oraz Recover. Ta strukturalna transformacja ma znaczenie dla środowisk chmurowych, gdzie granica między operacjami IT a bezpieczeństwem jestem mało widocza. Nowy model kładzie nacisk na ciągłe doskonalenie, gdzie lekcje wyciągnięte z każdego zdarzenia są natychmiastowo identyfikowane w celu aktualizacji zasobów i oceny ryzyka. Można powiedzieć, że wersja 3 w porównaniu do 2 kładzie zdecydowanie większy nacisk na odporność zamiast skupiać się na samym zdarzeniu.

2.2 Porównanie struktur NIST SP 800-61 Revision 2 i 3

Cecha	NIST SP 800-61 Revision 2 (Model 2012)	NIST SP 800-61 Revision 3 (Model 2025)
Główne podejście	Liniowy cykl życia incydentu	Mapowanie na funkcje CSF 2.0 (Govern, Identify, Protect, Detect, Respond, Recover)
Charakter procesu	Reaktywny i taktyczny	Proaktywny, zintegrowany z zarządzaniem ryzykiem
Rola automatyzacji	Wspomagająca, opcjonalna	Fundamentalna dla obsługi skali
Lekcje wyciągnięte z incydentu	Działania po incydencie	Ciągłe doskonalenie w pętli zwrotnej
Kontekst infrastruktury	Zorientowany na on-premise	Zorientowany na chmurę i środowiska hybrydowe

Zrozumienie tych zmian jest niezbędne dla organizacji planujących migrację lub optymalizację procesów bezpieczeństwa. „Revision 3" odchodzi od sztywnego podręcznika działań na rzecz elastycznego modelu opartego na wynikach, co pozwala na lepszą koordynację działań w Modelu Odpowiedzialności Współdzielonej. W tym układzie, podczas gdy dostawca usług chmurowych przejmuje ciężar realizacji funkcji takich jak Protect czy Detect, klient stawia nacisk na płaszczyznę tożsamości oraz ochronę danych. Podział ten sprawia, że reagowanie na incydenty w chmurze staje się procesem wysoce zintegrowanym z API dostawcy wymuszając od zespołów SOC nie tylko wiedzy z zakresu cyberbezpieczeństwa, ale również dogłębnego zrozumienia architektury chmurowej.

3. Porównanie on-premise i cloud w kluczowych domenach

Skuteczna analiza porównawcza wymaga zestawienia procesów on-premise i cloud w domenach, które determinują efektywność operacyjną zespołów bezpieczeństwa. Takimi domenami jest kontrola, widoczność, cykl życia IR, informatyka śledcza, automatyzacja oraz prawo i regulacje. Wybór powyższych obszarów nie jest przypadkowych ponieważ odzwierciedlają one fundamentalną zmianę w sposobie postrzegania statycznej architektury bezpieczeństwa od tej dynamicznej. Zestawienie to pozwoli wykazać, że choć cele reagowania na incydenty pozostają niezmienne to metody ich osiągania są już różne.

3.1 Kontrola i model odpowiedzialności współdzielonej

3.1.1 Absolutna kontrola w środowisku on-premise

W środowisku on-premise organizacja sprawuje absolutną kontrolę nad całym stosem technologicznym, od fizycznej ochrony centrum danych, przez okablowanie sieciowe, sprzęt serwerowy, warstwę wirtualizacji, aż po systemy operacyjne i aplikacje. Taka architektura pozwala na stosowanie głębokich inspekcji oraz fizyczne odizolowanie zainfekowanych maszyn. Stanowi to tradycyjny i wysoce skuteczny środek zaradczy w fazie powstrzymywania incydentów.

Pełna kontrola oznacza jednak również pełną odpowiedzialność. Organizacja musi samodzielnie zapewnić aktualność oprogramowania, prawidłową konfigurację zapór sieciowych, segmentację sieci oraz ciągłość monitorowania. Każdy błąd konfiguracyjny lub zaniedbanie proceduralne leży wyłącznie po stronie klienta, bez możliwości przerzucenia odpowiedzialności na stronę trzecią.

3.1.2 Model odpowiedzialności współdzielonej w chmurze

W środowiskach chmurowych kontrola ma charakter umowny i jest pochodną modelu odpowiedzialności współdzielonej. Zakres obowiązków klienta zmienia się diametralnie w zależności od przyjętego modelu usługi. Przykładowo w modelu SaaS klient traci kontrolę nad niemal całym stosem technologicznym. Nie ma dostępu do systemu operacyjnego ani do logów systemowych, chyba że dostawca jawnie udostępni odpowiednie interfejsy programistyczne lub panele administracyjne. Oznacza to, że w przypadku incydentu bezpieczeństwa zespół reagowania jest całkowicie uzależniony od danych, które dostawca zdecyduje się ujawnić i od czasu, w jakim to zrobi. Dla porównania w modelu IaaS sytuacja jest korzystniejsza z perspektywy klienta ponieważ zachowuje on kontrolę nad systemem operacyjnym i danymi, lecz fizyczna infrastruktura pozostaje domeną dostawcy.

3.2 Widoczność i telemetria

3.2.1 Możliwości i ograniczenia w środowisku on-premise

Widoczność w on-premise opiera się na statycznych punktach zbierania danych. Trzy podstawowe warstwy telemetrii to logi systemowe przesyłane przez Syslog, ruch sieciowy pozyskiwany z portów SPAN/TAP oraz agenci zainstalowani na stacjach roboczych i serwerach. Architektura ta jest przewidywalna, a topologia sieci rzadko ulega gwałtownym zmianom co sprzyja stabilności konfiguracji monitorowania.

Jednak statyczność on-premise to zarazem źródło jego ograniczeń w kontekście IR. Do głównych problemów możemy zaliczyć:

- **Szyfrowany ruch TLS** – W środowiskach z powszechnym protokołem TLS 1.3, bez wdrożenia inspekcji TLS, analiza sieciowa ogranicza się do metadanych przepływów uniemożliwiając wgląd w treść pakietów.
- **Martwe punkty warstwy aplikacji** – Bez agenta zainstalowanego bezpośrednio na hoście, infrastruktura sieciowa nie zapewnia wglądu w aktywność wewnątrzprocesową oraz lokalne wywołania systemowe.
- **Skalowalność i koszty retencji** – Przechowywanie pełnych przechwytów pakietów przez dłuższy czas jest kosztowne. Organizacje często ograniczają retencję do dni lub tygodni co może być niewystarczające przy incydentach wykrytych z opóźnieniem.

3.2.2 Taksonomia logów chmurowych

Środowiska chmurowe wprowadzają wielowarstwowy model telemetrii, który wykracza daleko poza analogię do Syslog i portów SPAN. Spośród różnych kategorii szczególne znaczenie dla IR mają logi płaszczyzny zarządzania. W chmurze niemal każda operacja taka jak uruchomienie instancji czy zmiana polityki IAM realizowana jest przez wywołania API dostawcy. Oznacza to, że atakujący operujący skradzionymi kluczami API lub skompromitowaną rolą IAM nieodłącznie pozostawia ślad w logach CloudTrail czy Azure Activity Log o ile są one prawidłowo skonfigurowane.

Istotną pułapką jest jednak domyślna konfiguracja, gdyż nie wszystkie kategorie logów są włączane automatycznie. Przykładowo w usłudze AWS logi płaszczyzny danych wymagają jawnego włączenia w CloudTrail podobnie jak logi zapytań do baz danych RDS. W takim przypadku koniecznym wydają się audyty mające na celu wykrycie luk w pokryciu logowania.

3.2.3 Narzędzia natywne dostawcy a zewnętrzny SIEM

Decyzja dotycząca architektury widoczności sprowadza się do wyboru między poleganiem na natywnych narzędziach dostawcy a eksportem danych do zewnętrznego systemu. Każde podejście wiąże się z innymi kompromisami operacyjnymi i finansowymi.

Narzędzia natywne, takie jak AWS GuardDuty, Microsoft Defender for Cloud czy Google Security Command Center, oferują integrację z ekosystemem dostawcy, niskie opóźnienie w detekcji oraz gotowe modele ML trenowane na danych od wszystkich klientów platformy. Jednak ich słabością jest vendor lock-in oraz ograniczona widoczność w środowiskach wielochmurowych.

Zewnętrzny SIEM na przykład Splunk czy Microsoft Sentinel działające jako niezależna instancje zapewniają niezależność od dostawcy i możliwość korelacji zdarzeń, lecz wymagają znacznych nakładów na integrację.

W praktyce organizacje dojrzałe pod względem bezpieczeństwa stosują podejście hybrydowe w którym narzędzia natywne są pierwszą linią detekcji ze względu na niski czas reakcji i głęboką integracje. Uzupełnieniem jest eksport do zewnętrznego SIEM dla celów długoterminowej retencji i zachowania niezależności od dostawcy.

3.3 Cykl życia IR

Mimo że główne cele IR takie jak minimalizacja strat i powrót do normalnego działania pozostają niezmienne, fazy operacyjne ulegają modyfikacji.

3.3.1 Wykrywanie i analiza

W on-premise faza wykrywania często koncentruje się na sygnaturach malware i anomaliach sieciowych. W chmurze nacisk kładziony jest na detekcję anomalii w zachowaniu tożsamości oraz monitorowanie nietypowych wywołań API takich jak masowe tworzenie kopii zapasowych dysków przez nieautoryzowane konto.

3.3.2 Powstrzymywanie

Faza powstrzymywania incydentu w chmurze jest znacznie szybsza i bardziej precyzyjna dzięki automatyzacjom co wynika z możliwości głębokiej integracji z API dostawcy. Zamiast fizycznego odłączania kabla, playbooki SOAR mogą natychmiastowo zmienić reguły dla grup sieciowych, unieważnić tokeny sesji użytkownika czy odizolować zainfekowany pod w środowiskach takich jak Kubernetes.

3.3.3 Usuwanie i odzyskiwanie

Najbardziej radykalną zmianę widać w fazie usuwania skutków ataku i przywracania środowiska. W modelu on-premise faza ta często wiąże się z czasochłonnym procesem

kwarantanny, skanowania programami antywirusowymi i czyszczenia zainfekowanych serwerów z zachowaniem ich ciągłości działania. W środowiskach chmurowych stosuje się podejście oparte na infrastrukturze niemutowalnej. Zamiast naprawiać zainfekowany system, podejście zakłada jego całkowite zniszczenie i automatyczne wdrożenie nowej, czystej instancji ze zweryfikowanego obrazu przy użyciu metodologii Infrastructure as Code co drastycznie skraca czas.

3.4 Informatyka śledcza

Tradycyjna informatyka śledcza opiera się na zabezpieczaniu obrazów binarnych dysków bit po bicie oraz zrzutach pamięci RAM z fizycznie dostępnych maszyn. W chmurze proces ten jest realizowany poprzez mechanizmy logiczne dostarczane przez dostawcę usług chmurowych. Przykładem jest tworzenie kopi zapasowych wolumenów EBS w AWS czy zarządzanie kopiami w Azure. Utworzone w ten sposób obrazy są następnie podłączane do bezpiecznych, wyizolowanych stacji śledczych wewnątrz chmury w celu dokonania analizy. Pobranie zrzutu pamięci RAM stanowi jednak w chmurze znacznie większe wyzwanie ze względu na ograniczenia hiperwizora i brak bezpośredniego dostępu do sprzętu. Zmusza to zespoły IR do wykorzystywania dedykowanych agentów systemowych lub specyficznych wywołań API dostawcy. Dodatkową trudność potęguje efemeryczna natura środowisk chmurowych, w których infrastruktura jest dynamicznie powoływana i niszczona.

Kolejnym, i być może największym, wyzwaniem w śledztwach chmurowych jest zapewnienie integralności i autentyczności dowodów cyfrowych. W środowisku współdzielonym udowodnienie przed organami ścigania, że dane nie zostały zmanipulowane przez innych użytkowników, osoby trzecie lub samego dostawcę, wymaga rygorystycznego podejścia technologicznego. W tym celu organizacje muszą stosować zaawansowane techniki kryptograficzne, takie jak sumy kontrolne i logi z certyfikatami czasu. Same dowody oraz powiązane z nimi dzienniki zdarzeń muszą być natychmiast transferowane i przechowywane w wysoce izolowanych, niemodyfikowalnych kontenerach typu WORM. Zapewnia to technologiczną gwarancję nienaruszalności materiału od momentu jego zebrania aż do ewentualnego postępowania sądowego.

3.5 Porównanie technicznych aspektów informatyki śledczej

Aspekt techniczny	On-Premise	Cloud
Pozyskiwanie obrazu dysku	Fizyczny obraz bitowy	Snapshoty logiczne wolumenów wirtualnych
Dostęp do pamięci RAM	Lokalne narzędzia, dostęp do konsoli	Ograniczony zależny od dostawcy, zazwyczaj poprzez agenty lub zrzuty VM
Źródła sieciowe	Pełne PCAP z portów TAP/SPAN	Logi przepływu, ograniczone PCAP natywne
Analiza artefaktów	Pliki rejestru, MFT, dzienniki zdarzeń OS	Logi API, metadane tożsamości, logi orkiestracji
Gwarancja integralności	Fizyczna blokada zapisu, sumy kontrolne	Logi niezmienialne, API hash verification

3.6 Automatyzacja i SOAR

Automatyzacja procesów bezpieczeństwa w środowiskach on-premise często napotyka na bariery wynikające z heterogeniczności infrastruktury. Różnorodność protokołów komunikacyjnych, obecność systemów typu legacy pozbawionych nowoczesnych interfejsów API oraz konieczność manualnej konfiguracji urządzeń fizycznych sprawiają, że pełna orkiestracja działań jest trudna i kosztowna w implementacji.

Chmura, będąc środowiskiem z natury programowalnym, redefiniuje te procesy, umożliwiając głęboką automatyzację na każdym etapie cyklu IR. Rozwiązania klasy SOAR stają się tu niezbędnym ogniwem, integrując alerty z natywnych systemów SIEM takimi jak Microsoft Sentinel czy Google Chronicle. Dzięki podejściu Security as Code, odpowiedzi na zagrożenia mogą być wersjonowane i testowane w taki sam sposób jak kod aplikacji.

W modelu chmurowym powszechnie stosuje się automatyczne playbooki, które są uruchamiane przez zdarzenia w czasie rzeczywistym. Na przykład, wykrycie przez AWS GuardDuty aktywności typu "Tor Exit Node" może automatycznie wyzwolić funkcję, która doda odpowiedni adres IP do listy blokad w AWS WAF i powiadomi analityka na dowolnym skonfigurowanym komunikatorze.

3.7 Prawo i aspekty regulacyjne

Aspekt prawny jest jedną z najbardziej skomplikowanych domen w zestawieniu on-premise oraz cloud, głównie ze względu na problem jurysdykcji. W on-premise dane zazwyczaj znajdują się w jednym państwie, co upraszcza stosowanie lokalnego prawa i procedur karnych. Organizacja posiada bezpośrednią kontrolę nad dowodami, co ułatwia spełnienie wymogów w zakresie retencji danych i ochrony prywatności. W chmurze dane mogą być rozproszone geograficznie, co prowadzi do konfliktów między regulacjami takimi jak europejskie RODO chroniącym prywatność obywateli UE i amerykański CLOUD Act, który w określonych warunkach umożliwia organom ścigania USA dostęp do danych przechowywanych przez amerykańskich dostawców, nawet jeśli fizycznie znajdują się one na serwerach w Europie.

W Polsce w 2026 roku kluczowym uwarunkowaniem jest wdrożenie dyrektywy NIS2 poprzez nowelizację ustawy o Krajowym Systemie Cyberbezpieczeństwa. Nowe przepisy drastycznie zwiększają liczbę podmiotów objętych nadzorem i wprowadzają rygorystyczne terminy zgłaszania poważnych incydentów. Jest to 24h na wczesne ostrzeżenie oraz 72h na zgłoszenie incydentu. Sektor finansowy dodatkowo musi spełniać wymogi rozporządzenia DORA, które nakłada szczególne obowiązki w zakresie zarządzania ryzykiem ze strony zewnętrznych dostawców usług ICT.

4. Analiza luk w procesach tradycyjnych

Przeniesienie procesów IR z on-premise do chmury bez ich adaptacji prowadzi do powstania niebezpiecznych luk operacyjnych. Tradycyjne modele zakładają pewien stopień trwałości zasobów i stabilności topologii sieci oraz możliwości bezpośredniego dostępu fizycznego. W chmurze żadne z tych założeń nie ma zastosowania. Wynika z tego konieczność gruntownego przemodelowania procesów, procedur i wymaganego stacku technologicznego.

4.1 Tożsamość jako nowy obwód bezpieczeństwa

W tradycyjnym podejściu do IR głównym celem powstrzymywania jest odcięcie zainfekowanego hosta od sieci. Procedura polega na bezpiecznym zamknięciu portu, zmianie przypisanego VLAN albo odłączeniu fizycznego połączenia sieciowego. Takie działania blokują dalsze rozpowszechnianie się malwaru i uniemożliwia atakującemu komunikowanie się z siecią.

W chmurze ta procedura jest całkowicie nieskuteczna, jeśli atakujący dysponuje skradzionymi kluczami dostępowymi lub tokenami sesyjnych. W przypadku gdy pracownik zostałby zafishingowany i jego hasło wylądowałoby w rękach atakującego ten uzyskuję dostęp do konta AWS pracownika, a następnie do skonfigurowanych poświadczeń lub kluczy dostępowych przechowywanych w zmiennych środowiskowych kontenera. W tym momencie izolacja sieciowa instancji EC2, na której był zainstalowany kod atakującego, jest niewystarczająca. Atakujący nie operuje z wewnątrz tej instancji a operuje z internetu, korzystając ze skradzionych kluczy API. Może bez przeszkód czytać zawartość zasobów w dowolnym regionie, modyfikować polityki IAM, dając sobie dodatkowe uprawnienia, uruchamiać nowe instancje w innym regionie geograficznym, eksportować dane do zewnętrznych bucketu S3 a wszystko to bez jakiegokolwiek fizycznego połączenia sieciowego z zainfekowaną maszyną.

4.2 Eksplozja skali i prędkości

4.2.1 Ataki na prędkości API

Tradycyjne procesy IR opierają się na założeniu, że incydent rozwija się w ciągu godzin a nawet dni. Analitycy mają czas na ręczne dochodzenie a więc na zalogowanie się do systemów, przeanalizowanie logów, skonsultowanie się z zespołami operacyjnymi oraz sporządzenie raportów. Procedury kontaminacyjne mogą przebiegać w wolnym tempie, ponieważ rozpowszechnianie złośliwego oprogramowania jest ograniczone szybkością propagacji sieciowej i czasem potrzebnym na eksploitację.

W chmurze ścieżka ataku może przebiegać w ciągu minut lub sekund. Zautomatyzowany skrypt atakującego może pobrać dane z dziesiątków baz danych jednocześnie, uruchomić setki instancji obliczeniowych do celów kryptowalutowych lub ataku DDoS oraz zmodyfikować polityki bezpieczeństwa w czasie liczonym w minutach.

4.2.2 Potrzeba reagowania na prędkość maszyny

Konsekwencją jest konieczność wdrożenia automatycznych mechanizmów reagowania. Procedury polegające na ręcznym zalogowaniu się analityka do konsoli i ręcznej zmianie reguł sieciowych są skazane na porażkę. Rozwiązaniami które powinny być wdrażane są:

- **Automatyczne polityki -** Natychmiast reagujące reguły sieciowe. Przykładowo jeśli wykryto podejrzaną modyfikację w API, natychmiast usuń te zmiany i wyślij alert.
- **Security orchestration (SOAR) -** Narzędzia takie jak AWS Security Hub, Microsoft Sentinel Playbooks czy platformy takie jak Splunk Phantom mogą automatycznie orkiestrować odpowiedź między wieloma systemami a więc unieważnić tokeny, zablokować IP, zmienić polityki oraz rozpocząć dochodzenie śledcze.
- **Infrastructure as Code -** Bezpieczeństwo może być wdrożone poprzez kod, co pozwala na natychmiastowe przywrócenie bezpiecznego stanu poprzez re-deployment.

4.3 Efemeryczność artefaktów i "Fog of War"

4.3.1 Kontenery bez tradycyjnego systemu plików

Znaczna część tradycyjnego IR opiera się na analizie artefaktów pozostawionych przez atakującego na dysku twardym ofiary. W chmurze, szczególnie w architekturze serverless, taki paradygmat musi być całkowicie przemodelowany. AWS Lambda, Google Cloud Functions czy Azure Functions nie posiadają systemu plików pomiędzy wywołaniami. Kontener Docker, w którym uruchomiona jest funkcja, może istnieć przez zaledwie kilka sekund, a następnie być zniszczony. Jakikolwiek artefakt w pamięci procesu, na dysku tymczasowym czy w zmiennych środowiskowych, zostanie bezpowrotnie utracony.

4.3.2 Fog of War

Jedynym niezawodnym źródłem informacji o tym, co działo się wewnątrz funkcji serverless lub kontenera, są logi aplikacyjne. Wyzwaniem dla analityka IR stanowi to, że owe logi mogą być rozproszone po setkach lub tysiącach instancji. W scenariuszu ataku korupcyjnego, gdzie atakujący manipuluje aplikacją w celu ekstrakcji danych, możliwe jest, że złośliwe żądanie przejdzie przez wiele warstw, gdzie każdy skok powinien być rejestrowany w logach, ale jeśli logi nie są prawidłowo generowane i wzbogacane o identyfikator, zestawienie pełnej ścieżki żądania jest niemal niemożliwe. Taką sytuację określa się jako "Fog of War".

5. Modelowanie procesów docelowych - Reagowanie napędzane przez kod

Projektowanie docelowego schematu reagowania w chmurze musi opierać się na zastąpieniu manualnych działań przez skrypty i systemy SOAR uruchamiane na podstawie telemetrii API. Podejście to zmienia proces IP z reaktywnego i podatnego na błędy ludzkie w proaktywne, zautomatyzowane i w pełni przewidywalne.

5.1 Architektura zdarzeniowa

W nowoczesnym środowisku SOC, detekcja incydentu nie kończy się jedynie na wygenerowaniu alertu w systemie, ale wyzwala łańcuch zdarzeń w architekturze "serverless". Przykładowy przepływ dla wykrycia błędnej konfiguracji publicznie dostępnego zasobu takiego jak bucket S3 w chmurze AWS:

- **Detekcja -** AWS Config lub CloudWatch Events wykrywa zmianę polityki bucketu na publiczną.
- **Trigger -** Zdarzenie jest przesyłane do Amazon EventBridge.
- **Automatyczna akcja -** Funkcja Lambda analizuje tagi zasobu i natychmiastowo przywraca politykę "Private" zgodnie ze zdefiniowanym baseline'em IaC.
- **Wzbogacenie -** System SOAR pobiera logi z CloudTrail, aby zidentyfikować, który użytkownik dokonał zmiany i czy było to działanie celowe czy wynik kompromitacji klucza.
- **Powiadomienie -** Analityk otrzymuje pełny kontekst zdarzenia wraz z informacją o automatycznie podjętej akcji.

5.2 Przykładowe automatyzacje SOAR w chmurze

Scenariusz ataku	Wyzwalacz (Trigger)	Akcja automatyczna (Playbook)	Korzyść operacyjna
Kompromitacja poświadczeń	Wykrycie logowania z nietypowego IP/kraju	Unieważnienie sesji, wymuszenie MFA, blokada konta	Skrócenie czasu dla osoby atakującej
Atak Brute-force	Wielokrotne nieudane logowania w krótkim czasie	Czasowa blokada źródłowego IP w Firewallu/WAF	Zapobieganie przejęciu konta

Ransomware na maszynie wirtualnej	Alert z EDR o masowym szyfrowaniu plików	Odizolowanie VM, wykonanie snapshotu EBS	Ograniczenie "blast radius" i zabezpieczenie dowodów
Exfiltracja danych z DB	Gwałtowny wzrost ruchu wychodzącego z bazy danych	Nałożenie limitów przepustowości (Rate Limiting),	Zapobieganie utracie dużej ilości danych

5.3 Infrastruktura jako kod (IaC) jako mechanizm odzyskiwania

Podejście Infrastructure as Code za pomocą narzędzi takich jak Terraform czy CloudFormation rewolucjonizuje fazę odzyskiwania. W tradycyjnym IR odzyskiwanie polega na żmudnym przywracaniu danych z kopii zapasowych i ręcznym rekonfigurowaniu systemów. W chmurze, dzięki IaC, infrastruktura może być traktowana jako niezmienna.

W przypadku podejrzenia, że klaster Kubernetes został skompromitowany na poziomie warstwy kontrolnej, zamiast go naprawiać, zespoły IR mogą wykonać snapshoty do celów śledczych, następnie całkowicie usunąć skażony klaster a ostatecznie uruchomić nowy, identyczny klaster z czystych, zweryfikowanych szablonów IaC w ciągu kilku minut. Podejście to eliminuje ryzyko pozostawienia backdoor’ów przez atakującego w systemie operacyjnym.

6. Uwarunkowania prawne i regulacyjne w Polsce na rok 2026

Dla organizacji operujących na terytorium Polski, analiza procesów IR musi uwzględniać dynamicznie zmieniające się otoczenie legislacyjne, które w 2026 roku osiągnęło wysoki poziom rygoru. Zgodność z prawem przestała być jedynie kwestią audytów dokumentacji, a stała się twardym wymogiem operacyjnym, definiującym architekturę techniczną i czasy reakcji zespołów bezpieczeństwa.

6.1 Nowelizacja UKSC i dyrektywa NIS2

Z dniem 2 kwietnia 2026 roku weszła w życie nowelizacja ustawy o Krajowym Systemie Cyberbezpieczeństwa, będąca transpozycją unijnej dyrektywy NIS2. Regulacja ta drastycznie zmienia podejście do raportowania i obsługi incydentów, co ma bezpośrednie przełożenie na wybór modelu technologicznego. Najważniejsze konsekwencje dla procesu IR, które niesie ta ustawa to:

- Rozszerzenie zakresu ustawy na sektory takie jak gospodarka odpadami, produkcja żywności czy administracja publiczna, co zmusza te branże do budowy profesjonalnych zdolności reagowania.
- Nałożono obowiązek podłączenia się do rządowego systemu teleinformatycznego S46, służącego do scentralizowanego zgłaszania incydentów do właściwych terytorialnie i

sektorowo zespołów CSIRT. W środowiskach chmurowych integracja ta może być w pełni zautomatyzowana poprzez API i systemy SOAR.

- Wprowadzono bezwzględny obowiązek przekazania wczesnego ostrzeżenia o incydencie poważnym w ciągu 24 godzin od jego wykrycia, a pełnego raportu w ciągu 72 godzin. Spełnienie tego wymogu bez zautomatyzowanej telemetrii chmurowej jest niezwykle trudne.
- Za brak wdrożenia adekwatnych środków zarządzania incydentami grożą kary do 10 mln EUR lub 2% rocznych przychodów.

6.2 Sektor finansowy i rozporządzenie DORA

W 2026 roku sektor bankowy jest już w pełni objęty rozporządzeniem DORA (Digital Operational Resilience Act). Regulacja ta kładzie ogromny nacisk na odporność operacyjną w kontekście korzystania z usług chmurowych. Wymuszając na organizacjach testy penetracyjne oparte na zagrożeniach, poprzez regularne ćwiczenia symulujące ataki na infrastrukturę chmurową. Sektor finansowy musi także sprawować nadzór nad dostawcami usług chmurowych. Bank musi mieć możliwość przeprowadzenia audytu procesów IR u swojego dostawcy chmurowego.

6.3 Dopuszczalność dowodów cyfrowych z chmury

W polskim procesie karnym i cywilnym w 2026 roku dowody elektroniczne są traktowane równorzędnie z dokumentami papierowymi, pod warunkiem zachowania ich integralności. Wyzwanie w chmurze polega na udowodnieniu, że logi API pobrane z konsoli CSP nie zostały zmodyfikowane. Dlatego krytyczne jest wykorzystywanie usług typu "Object Lock" lub "Immutable Storage", które uniemożliwiają edycję danych nawet przez użytkownika z uprawnieniami administratora.

7. Wnioski i rekomendacje strategiczne

Dokonana analiza porównawcza wykazuje, że migracja do chmury nie jest jedynie zmianą lokalizacji serwerów, ale przejściem do nowego paradygmatu operacyjnego. W tak wysoce zautomatyzowanym i efemerycznym środowisku klasyczne, manualne metody reagowania na incydenty wywodzące się ze środowisk on-premise stają się nie tylko nieefektywne, ale wręcz ryzykowną luką w architekturze bezpieczeństwa.

7.1 Kluczowe wnioski z niniejszego raportu

●Tradycyjna ochrona oparta na zaporach sieciowych i fizycznej izolacji sieci traci na znaczeniu na rzecz płaszczyzny tożsamości. W chmurze rygorystyczne zarządzanie uprawnieniami, wdrażanie koncepcji Zero Trust oraz polityk dostępu warunkowego stają się fundamentem zapobiegania incydentom.

●Zautomatyzowana natura chmury sprawia, że postępują w ciągu sekund. Wymusza to porzucenie manualnych procesów decyzyjnych na rzecz wdrażania systemów SOAR oraz playbooków reagujących w czasie rzeczywistym.

●Zbieranie dowodów musi być zintegrowane z orkiestracją zasobów, aby uniknąć utraty artefaktów.

●W obliczu dyrektywy NIS2 i nowelizacji ustawy o KSC, organizacje muszą zmuszone są zoptymalizować proces detekcji i raportowania. Spełnienie wymogu zgłoszenia poważnego incydentu przez krajowy System S46 w okienku 24/72 godzin jest operacyjnie niemożliwe bez w pełni zautomatyzowanej telemetrii na poziomie chmury.

7.2 Rekomendacje dla organizacji

●**NIST SP 800-61 Revision 3 -** Rekomenduje się ostateczne odejście od linearnego podejścia do incydentów na rzecz modelu ciągłego zarządzania ryzykiem. Integracja procesów IR z funkcjami ramowymi NIST CSF 2.0 zapewni elastyczność niezbędną do obsługi hybrydowych i chmurowych środowisk operacyjnych.

●**Wdrożenie ekosystemu CNAPP i CDR -** Zespoły bezpieczeństwa powinny zainwestować w platformy typu CNAPP oraz CDR. Rozwiązania te dostarczają krytyczną widoczność w warstwach niedostępnych dla tradycyjnych narzędzi on-premise.

●**Ewolucja kompetencji zespołów -** Niezbędne jest przekwalifikowanie analityków bezpieczeństwa z tradycyjnej analizy sieciowej na analizę logów audytowych specyficznych dla rozwiązań oraz pozyskiwanie dowodów bezpośrednio poprzez interfejsy API dostawców.

●**Odzyskiwanie poprzez infrastrukturę** niemutowalną - Standardem powinno stać się przywracanie usług ze sprawdzonych szablonów kodu zamiast naprawy skażonych systemów.